

COMPREHENSIVE SUMMARY OF ADIB-EGYPT



ADIB Egypt Bank
[Information Security-C1 - Internal]

Contents

Comprehensive Summary of ADIB-Egypt Email Acceptable Use Policy	2
Multiple-Choice Questions	Error! Bookmark not defined.
Summary of ADIB-Egypt Password Policy	3
Multiple-Choice Questions	Error! Bookmark not defined.
Summary of ADIB EGYPT Security Incident-Handling Policy	4
Multiple-Choice Questions	Error! Bookmark not defined.
Summary of ADIB EGYPT Information Asset Classification & Handling Policy	5
Multiple-Choice Questions	Error! Bookmark not defined.
Summary of ADIB-Egypt Personnel Policy	7
Multiple-Choice Questions	Error! Bookmark not defined.
Summary of ADIB-Egypt Clear Desk and Clear Screen Policy	8
Multiple-Choice Questions	Error! Bookmark not defined.

Comprehensive Summary of ADIB-Egypt Email Acceptable Use Policy

Introduction

The ADIB-Egypt Email Acceptable Use Policy is established to ensure the proper and secure use of our email system. This policy is applicable to all ADIB-Egypt staff and associated personnel, including contractors, freelancers, consultants, trainees, vendors, and subcontractors.

Key Points

1. **Email Management and Usage**
 - Outgoing emails over 20 MB require prior authorization.
 - Emails containing sensitive information must be reviewed and approved.
2. **Account Management**
 - Email accounts are to be decommissioned upon staff departure.
 - Forwarding work emails to personal accounts is prohibited.
3. **Remote Access and Out of Office**
 - Use ADIB-Egypt laptops and VPN for remote email access.
 - Set out of office messages with return dates and alternative contact information.
4. **Unacceptable Email Use**
 - Prohibited content includes inappropriate, offensive, or fraudulent material.
5. **Personal Use of Email**
 - Limited personal use is permitted under specific conditions.
6. **Archiving and Confidentiality**
 - Adhere to mailbox size limits and email archiving policies.
 - Maintain confidentiality of sensitive information.
7. **Monitoring and Compliance**
 - All emails are monitored for adherence to this policy.
 - Non-compliance may lead to disciplinary action.

Summary of ADIB-Egypt Password Policy

Introduction

- **Purpose:** Establish standards for strong password creation, protection, and change frequency to prevent unauthorized use and potential liabilities.
- **Scope:** Applies to all ADIB-Egypt employees, contractors, freelancers, consultants, trainees, vendors, and subcontractors.
- **Objective:** Govern user access in terms of authentication and account lifecycle, preventing compromised accounts and unauthorized access.

Policy Statements

1. **Normal User Account Passwords:**
 - Minimum 8 characters, including a mix of lower and upper-case letters, digits, and special characters.
 - Maximum password age: 35 days; minimum: 1 day.
 - Passwords must not repeat the previous 10.
 - Must change password at first login; account locked after 5 failed attempts.
2. **Tier Accounts:**
 - Tier0: Critical systems with high privileged access; 14-character minimum, 35-day maximum age.
 - Tier1: Administrative permissions over application/database servers; similar requirements as Tier0.
 - Tier2: Administrative permissions over employee workstations and servers; similar requirements as Tier0 and Tier1.
3. **Privileged Service Accounts:**
 - Minimum 14-character password; never expires.
 - Dual custody basis for password development.
4. **APIs Authentication:**
 - Randomly generated access tokens with a minimum length of 64 characters.
 - Various authentication methods including IP addresses and token identifiers
5. **Remote Access Users:**
 - Two-factor authentication mandatory for all remote access.
6. **Password Protection Standards:**
 - Passwords classified as C3 – Secret.
 - Strict non-sharing and non-reversible encryption policy.
7. **Password Communication Standard:**
 - Passwords communicated via email or SMS; default and temporary passwords must be changed at first login.
8. **Password Reset and Change Standard:**
 - Passwords reset only for authorized users; system logs all changes.
9. **disable User account:**
 - Information technology department shall disable an account if it has not been used for 60 days from the creation or the time the password has been reset then delete the account after 90 day

Roles and Responsibilities

- **Information Security Department:** Annual review and monitoring of the policy, educating personnel about password risks.
- **Information Technology Department:** Implementation of all controls mentioned in the policy.

Enforcement and Compliance

- Mandatory adherence by all personnel.
- Violations may lead to disciplinary action, including termination.

Exceptions and KPIs

- Exceptions based on business or ITD justifications.
 - KPIs include tracking unauthorized password resets and account lock status.
-

Summary of ADIB EGYPT Security Incident-Handling Policy

Purpose and Scope

- **Objective:** To respond systematically to incidents, minimize loss or theft of information, and deal with legal issues during incidents.

Definition and Stakeholders

- **Incident Definition:** Includes events like system crashes, unauthorized access to sensitive data, and execution of malicious code.
- **Stakeholders:** Chief Information Security Officer, Chief Information Officer, Business Information Security Head, Cyber Security Head, Physical Security, Operation Risk, IT team.

Incident Rating Guidelines

- **Severity Levels:**
 - Severity 1: Total operational failure, severe confidentiality breaches.
 - Severity 2: Major breakdown, severe confidentiality breaches.
 - Severity 3: Partial failure, confidentiality breaches.
 - Severity 4: Low impact, isolated confidentiality breaches.

Reporting

- **Mandatory Reporting:** All suspected or detected incidents must be reported and logged for investigation.

Incident Response Team

- **Formation and Responsibilities:** Managed by the Chief Information Security Officer; responsible for handling incidents, identifying causes, and preventing reoccurrence.

Incident Response Process

- **Mechanisms:** Includes telephone, email, web interface, and direct contact. The team educates staff on incident reporting and documentation.

Incident Rating and Classification

- **Severity Rating:** Incidents must be rated according to their business or technical impact. Compliance officers are responsible for ensuring incidents are properly rated and classified as C2-restricted distribution or higher.

Incident Response Plan

- **Plan Requirements:** A detailed incident response plan must be in place, considering both business and technical perspectives. It should define actions to handle, contain, and recover from incidents.

Follow-Up Actions

- **Review and Improvement:** Mandatory follow-up meetings to review incident handling, determine necessary changes, and assess the true cause and impact of the incident.

Summary of ADIB EGYPT Information Asset Classification & Handling Policy

1. Scope of Application

- **Purpose:** To comply with international and local data protection regulations.
- **Method:** Classify assets based on value, criticality, and sensitivity.
- **Goal:** Ensure security is cost-effective and focused on high-importance assets.

2. Security Responsibilities

- **Owner:** Responsible for asset accuracy, completeness, classification, and accessibility.
- **Custodian:** Implements security controls, develops, and maintains security measures.
- **User:** Must understand and comply with information security policies and legislation.

3. Asset Inventory

- Maintain an updated asset inventory/registry list including critical details.

- Regularly review the asset inventory at least once annually.

4. Asset Owner Responsibilities

- Determine asset value, sensitivity, and criticality.
- Ensure appropriate asset protection.
- Specify authorized access and usage.

5. Classification Scheme

- **C0 - Public:** Freely circulatable information without special protection.
- **General:** Sensitive Data that should be distributed outside ADIB it can be shared with third parties without an explicit approval.
- **C1 - Internal Use:** Information circulating within ADIB EGYPT, requiring basic protection.
- **C2 - Restricted Distribution:** Sensitive information shared among specific employees only.
- **C3 - Secret:** Extremely sensitive information, limited to named individuals.

6. Classification Levels

- **NC - Non Confidential/Public:** Minimal protection required, accessible to all.
- **Hardware and Physical Assets:** Classified based on the information they handle, store, or process

7. Financial Value of Hardware Assets

- Maintain a list of hardware assets including cost, depreciation rate, and replacement cost.

8. Asset Labeling

- Assets must be clearly labeled with their classification.
- Labels can be printed or electronic.

9. Additional Sub-Classification

- Additional sub-classifications as per business needs.

Summary of ADIB-Egypt Personnel Policy

Introduction

- **Purpose:** Establishes information security requirements for personnel hiring, followed by the HR department at three stages: Prior to employment, During employment, and Termination.

Scope

- **Applicability:** Applies to all employees, contractors, freelancers, consultants, trainees, vendors, and subcontractors of ADIB Egypt and its subsidiaries.

Objectives

1. Ensure personnel understand their roles and responsibilities.
2. Reduce risk of theft, fraud, or misuse of facilities.
3. Ensure hiring of trustworthy employees.
4. Make personnel aware of information security threats.
5. Ensure orderly exit or change of employment to protect organizational interests.

Policy Statements

1. **Prior to Employment:**
 - Mandatory pre-employment screening.
 - Confirmation of screening before offering employment.
 - Additional screening for promotions.
 - Includes resume examination, interviews, reference checks, and various background checks.
2. **During Employment:**
 - Awareness and agreement on security roles and responsibilities.
 - Implementation of information security controls.
 - Regular security awareness training.
 - Diverse mechanisms for raising security awareness.
3. **Disciplinary Process:**
 - A formal process to handle violations of ADIB-Egypt security policy.
 - Includes guidelines for handling disciplinary actions and escalation paths for severe violations.
4. **Termination:**
 - Formal exit procedure, including asset return, hand-over of duties, and disabling of service access.
 - Use of a termination checklist.
 - Management signoff required for checklist completion.

Key Performance Indicators

- Number of personnel not signing their security roles and responsibilities.
- Percentage of professional certificates verified prior to hiring.
- Number of pending NDAs for third parties and contractors.
- Number of disciplinary actions for security policy breaches.
- Number of resigned users with access not revoked or assets not returned.

Summary of ADIB-Egypt Clear Desk and Clear Screen Policy

Introduction

- **Purpose:** To maintain security and confidentiality of customer and ADIB information, reduce loss, present a positive image, minimize disorganization, and reduce workplace accidents.

Scope

- **Applicability:** This policy applies to all ADIB Egypt employees, contractors, freelancers, consultants, trainees, vendors, and subcontractors.

Policy Statements

- **Personnel must maintain a neat work environment.**
- Sensitive and confidential paperwork must be secured.
- Electronic media must be stored safely.
- PCs and terminals should be password-protected and logged off when unattended.
- Whiteboards should not display sensitive data.
- Printers and fax machines must be used carefully.
- Personal and ADIB items must be securely stored.
- Documents and electronic media should be put away at the end of the workday.
- Offices should be locked when unoccupied for extended periods.

Roles and Responsibilities

- **Information Security Team:** Responsible for maintaining, reviewing, monitoring, and auditing this policy.

Enforcement

- Personnel must adhere to the policy.
- Information Security may conduct sweeps to verify adherence.
- Violations may lead to disciplinary actions, including termination.

Key Performance Indicators

- Number of reported clear desk and clear screen policy violations per quarter.
